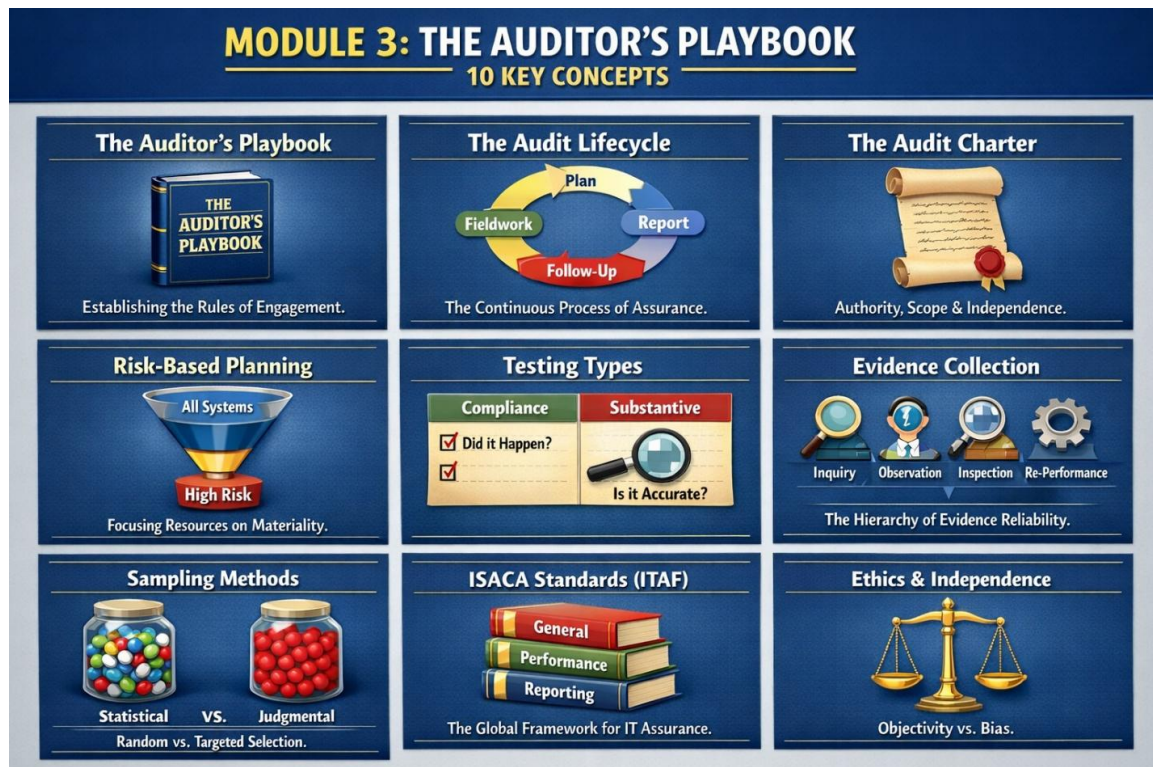


CMT 446 – IT Risk Management & Internal Controls

Module 3: Audit Standards, Methodology & Planning



Module Context and Learning Objectives

Audit as a Governance Function

Auditing exists to protect stakeholders by providing objective assurance. Management designs and operates controls, but auditors independently assess whether those controls are effective.

Without independence, audits lose credibility and become management reporting exercises rather than assurance activities.

The Audit Lifecycle

The audit lifecycle consists of planning, fieldwork, reporting, and follow-up. Each phase is essential to ensuring audit conclusions are defensible, repeatable, and actionable.

Follow-up is often the weakest phase in practice, yet it is critical for confirming that identified risks have been addressed.

Audit Charter, Authority, and Independence

The audit charter is a formal document approved by the Board or Audit Committee that grants authority, scope, and unrestricted access to systems and personnel.

Professional auditors must maintain independence and objectivity, even when findings are uncomfortable for management.

Risk-Based Audit Planning

Audit resources are finite, requiring prioritization based on risk. Risk-based audit planning focuses on areas with the highest potential impact, regulatory exposure, and likelihood of failure.

Key concepts include Annual Loss Expectancy (ALE), materiality, and business criticality.

Testing Approaches and Evidence

Compliance testing verifies whether controls exist and operate as designed, while substantive testing validates the accuracy and completeness of transactions and data.

Audit evidence follows a hierarchy, with re-performance considered the most reliable and inquiry the least reliable.

Case Study: The Audit That Was Too Late

This case study explores an audit failure where auditors relied heavily on compliance testing, lacked independence, and failed to escalate significant risks.

Students analyze how stronger audit planning, evidence collection, and ethical courage could have changed the outcome.

More Details:

Goal: Define the auditor's authority and the technical rigor required to verify risk controls.

Block 1: Foundations of Audit Authority (0:00 - 0:30)

- **The Audit Lifecycle:** Walking through the four core phases: Planning, Fieldwork, Reporting, and Follow-up.
- **The Audit Charter:**
 - **Definition:** A formal mandate approved by the Board of Directors or Audit Committee.

+2

- **Powers:** Grants unrestricted access to systems, staff, and sensitive records.

+2

- **Professional Reality:** Without a charter, the auditor has no standing to demand information.

Block 2: Risk-Based Planning & Materiality (0:30 - 1:00)

- **The Constraints:** Auditing is limited by time and budget.
- **Strategic Prioritization:** Audit high-risk areas first, driven by Annual Loss Expectancy (ALE), regulatory exposure, and business criticality.

+1

- **Materiality:** Defining errors that are significant enough to mislead stakeholders or affect financial statements.

+1

Block 3: Testing Types & Evidence Collection (1:00 - 1:30)

- **Compliance vs. Substantive Testing:**
 - **Compliance:** Verifying if controls exist and are operating (e.g., "Is the firewall on?").
- **Substantive:** Validating the actual data for correctness (e.g., tracing invoice payments).
- **Correlation:** Weak controls found in compliance testing necessitate more intensive substantive testing.

+1

- **Evidence Hierarchy:** Ranking reliability from Inquiry (lowest) to **Re-performance** (highest).

+2

Block 4: Case Study & Standards (1:30 - 2:00)

- **Case Study: The "Ghost Payroll" Audit:**
 - **Scenario:** An auditor uses **Judgmental Sampling** to target high-risk payroll items after compliance testing shows weak approval logs.

+1

- **Methodology:** The auditor performs a **Statistical Sample** of transactions to extrapolate errors to the full population.

+1

- **Professional Ethics:** Navigating Independence (not auditing your own work) and Objectivity.
- **Standards Review:** Implementing ISACA ITAF and ISO 19011.

+1